

Contents

Volume 01 — Security Fundamentals and Threats	1
L01: Introduction to Information Security	1
L02: Protection Vs Security	2
L03: Aspects of Security	3
L04: Security Problems	4
L05: User Authentication	5
L06: Orange Book	6
L07: Security Threats	7
L08: Program Threats	8
L09: Worms and Viruses	8
Volume 01 summary	9

Volume 01 — Security Fundamentals and Threats

Lectures L01-L09 · Weeks 1-3

L01: Introduction to Information Security

Learning objectives

- Define information security and its scope.
- Understand why security is essential in modern computing.

What is information security?

Information security is the practice of protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction. It encompasses:

- **Data** at rest (stored files, databases)
- **Data** in transit (network communications)
- **Data** in use (processing in memory)
- **Systems** that store, process, or transmit information

The security landscape

Modern organizations face threats from:

Threat actor	Motivation
Hackers / crackers	Financial gain, notoriety
Insider threats	Revenge, espionage
Nation-states	Intelligence, sabotage
Script kiddies	Curiosity, vandalism

Cost of breaches

Security failures result in financial loss, reputational damage, legal liability, and operational disruption. The average cost of a data breach continues to rise globally.

Defense in depth

No single control is sufficient. Effective security layers:

1. Physical security
 2. Network security (firewalls, IDS)
 3. Host security (OS hardening, patching)
 4. Application security (secure coding)
 5. Data security (encryption, access control)
 6. Human factors (training, awareness)
-

L02: Protection Vs Security

Learning objectives

- Distinguish protection from security.
- Relate protection mechanisms to security goals.

Protection

Protection refers to mechanisms that control access to system resources—ensuring that processes and users operate within authorized boundaries. Protection is an **internal** concern of the operating system:

- Memory protection (segmentation, paging)
- File permissions (read, write, execute)
- Process isolation
- Capability-based access control

Security

Security is the broader discipline encompassing protection plus:

- Threat analysis and risk management
- Cryptography
- Network security
- Policy and compliance
- Incident response

Relationship

Security = Protection + Threat management + Cryptography + Policy

Protection mechanisms are **building blocks** of security. A system can have protection without comprehensive security (e.g., file permissions without encryption), but not vice versa.

Trusted computing base (TCB)

The **TCB** is the totality of protection mechanisms within a system—the hardware, firmware, and software responsible for enforcing security policy. All security depends on the TCB’s correctness.

L03: Aspects of Security

Learning objectives

- State the CIA triad and extended security properties.
- Apply security principles to system design.

The CIA triad

Property	Definition	Example violation
Confidentiality	Information accessible only to authorized parties	Data breach, eavesdropping
Integrity	Information accurate and unaltered by unauthorized parties	Tampering, malware modification
Availability	Information and systems accessible when needed	DDoS attack, ransomware

Extended properties

Property	Definition
Authentication	Verifying identity of a user or system
Authorization	Granting access based on authenticated identity
Non-repudiation	Preventing denial of actions (digital signatures)
Accountability	Tracing actions to responsible parties (auditing)

Security principles

1. **Least privilege** — grant minimum necessary access.

2. **Separation of duties** — no single person controls critical functions.
3. **Fail-safe defaults** — deny by default; permit explicitly.
4. **Economy of mechanism** — keep security design simple.
5. **Complete mediation** — check every access.
6. **Open design** — security should not depend on secrecy of design (Kerckhoffs' principle).

Risk management

$$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$$

Security investments should be proportional to risk.

L04: Security Problems

Learning objectives

- Identify common security problems in computing systems.
- Classify vulnerabilities by origin.

Categories of security problems

1. **Design flaws** - Weak authentication protocols - Missing access controls - Insecure defaults
2. **Implementation bugs** - Buffer overflows - Race conditions - Input validation failures
3. **Operational failures** - Unpatched systems - Weak passwords - Misconfigured firewalls
4. **Human factors** - Social engineering (phishing) - Insider misuse - Poor security awareness

Vulnerability lifecycle

Discovery → Disclosure → Patch available → Deployment → Exploitation window closes

The **exploitation window**—time between disclosure and patch deployment—is when systems are most vulnerable.

Common vulnerability types (CWE)

CWE	Description
CWE-79	Cross-site scripting (XSS)
CWE-89	SQL injection
CWE-120	Buffer overflow

CWE	Description
CWE-287	Improper authentication
CWE-306	Missing authentication

L05: User Authentication

Learning objectives

- Compare authentication factors and methods.
- Evaluate password-based and biometric authentication.

Authentication factors

Factor	Type	Examples
Something you know	Knowledge	Password, PIN
Something you have	Possession	Smart card, token, phone
Something you are	Inherence	Fingerprint, iris scan
Somewhere you are	Location	GPS, IP geolocation

Multi-factor authentication (MFA)

Combining two or more factors significantly strengthens authentication:

$$P(\text{breach}) \approx P(\text{factor}_1) \times P(\text{factor}_2)$$

Password security

Storage: never store plaintext passwords. Use salted hashes:

$$h = H(\text{password} \parallel \text{salt})$$

Recommended algorithms: bcrypt, scrypt, Argon2.

Policy guidelines: - Minimum length ≥ 12 characters - Check against breached password databases - Rate-limit login attempts - Implement account lockout

Biometric authentication

Biometric	False Accept Rate	False Reject Rate
Fingerprint	Low	Low
Iris	Very low	Very low
Face	Moderate	Moderate

Biometrics cannot be changed if compromised—use as one factor, not sole authentication.

Single sign-on (SSO)

Protocols like OAuth 2.0, OpenID Connect, and SAML enable authentication across multiple services with a single credential.

L06: Orange Book

Learning objectives

- Describe the Trusted Computer System Evaluation Criteria (TCSEC).
- Understand security evaluation classes.

TCSEC (Orange Book, 1983)

The U.S. Department of Defense **Trusted Computer System Evaluation Criteria** (DoD 5200.28-STD) defined security requirements for computer systems. Though superseded by Common Criteria (ISO 15408), it established foundational concepts.

Evaluation classes

Class	Name	Key requirement
D	Minimal protection	No security features
C1	Discretionary security	User identification, file access control
C2	Controlled access	Object reuse, audit trail
B1	Labeled security	Mandatory access control (MAC)
B2	Structured protection	Covert channel analysis
B3	Security domains	Reference monitor, TCB
A1	Verified design	Formal verification of TCB

Key concepts introduced

- **Security kernel** — minimal TCB implementing reference monitor
- **Reference monitor** — mediates all access; tamper-proof, always invoked, small enough to verify
- **Mandatory access control (MAC)** — access based on security labels, not owner discretion
- **Discretionary access control (DAC)** — owner controls access permissions

Modern successors

- **Common Criteria (CC)** — international standard ISO/IEC 15408
 - **NIST SP 800-53** — security controls for federal systems
 - **CIS Controls** — prioritized cybersecurity best practices
-

L07: Security Threats

Learning objectives

- Classify threats by type and source.
- Apply threat modeling frameworks.

Threat classification

By intent: - **Passive** — eavesdropping, traffic analysis (no modification) - **Active** — modification, injection, denial of service

By origin: - **External** — attackers outside the organization - **Internal** — employees, contractors, partners

STRIDE threat model

Threat	Property violated	Example
Spoofing	Authentication	Impersonation
Tampering	Integrity	Data modification
Repudiation	Non-repudiation	Denying actions
Information disclosure	Confidentiality	Data leak
Denial of service	Availability	Flooding attack
Elevation of privilege	Authorization	Privilege escalation

Attack vectors

Internet → Firewall → DMZ → Internal network → Host → Application → Data

Each layer is a potential attack surface.

Threat intelligence

Organizations use threat feeds, honeypots, and security information sharing to anticipate and defend against emerging threats.

L08: Program Threats

Learning objectives

- Identify program-level security threats.
- Explain how malicious code exploits program vulnerabilities.

Program threat categories

1. **Malware** - Viruses, worms, trojans, ransomware, spyware
2. **Exploitation of vulnerabilities** - Buffer overflows, format string bugs, integer overflows
3. **Logic flaws** - Race conditions (TOCTOU) - Improper error handling revealing information

Virus vs. worm vs. trojan

Type	Replication	User action required	Network spread
Virus	Yes	Yes (open file)	No
Worm	Yes	No	Yes
Trojan	No	Yes (install)	Optional

Rootkits

Rootkits hide their presence by modifying OS kernel or firmware, subverting integrity checking and logging mechanisms.

Defenses

- Code signing and verification
 - Sandboxing and application isolation
 - Static and dynamic analysis (SAST/DAST)
 - Principle of least privilege for processes
-

L09: Worms and Viruses

Learning objectives

- Describe virus and worm propagation mechanisms.
- Analyze historical examples and defenses.

Computer virus structure

A typical virus has four components:

1. **Infection mechanism** — how it attaches to host programs
2. **Trigger** — condition for payload activation
3. **Payload** — malicious action (delete files, display message)
4. **Stealth** — evasion of detection

Infection strategies

Strategy	Description
Companion	Creates .com file alongside .exe
Macro	Infects document macros (Word, Excel)
Boot sector	Infects MBR or boot sector
Polymorphic	Changes signature each infection
Metamorphic	Rewrites own code structure

Worm propagation

Worms spread autonomously across networks. The **basic reproduction number** R_0 measures spread:

$$R_0 = \beta \times D$$

where β is infection rate and D is duration of infectivity. If $R_0 > 1$, epidemic spread occurs.

Notable examples

Worm/Virus	Year	Impact
Morris Worm	1988	First internet worm; ~6,000 systems
ILOVEYOU	2000	Email worm; \$10B+ damage
Code Red	2001	IIS vulnerability; 359,000 hosts
WannaCry	2017	Ransomware worm; EternalBlue exploit
Stuxnet	2010	Targeted ICS/SCADA systems

Antivirus techniques

1. **Signature-based** — match known malware patterns
2. **Heuristic** — detect suspicious behavior
3. **Sandboxing** — execute in isolated environment
4. **Machine learning** — classify files by features

Volume 01 summary

Lecture	Core concept
L01	Information security definition
L02	Protection vs. security
L03	CIA triad, security principles
L04	Security problems, vulnerabilities
L05	Authentication methods
L06	Orange Book, evaluation criteria
L07	Threat classification, STRIDE
L08	Program threats
L09	Viruses and worms

Next: [Volume 02 — System Threats and Classical Cryptography](#)